

# Vulnerability Assessment Report

1<sup>st</sup> January 2025

---

## System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

## Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 2025 to August 2025. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

## Purpose

- *The database server is very valuable to the business as it stores the data and PII/SPII of customers and employees.*
- *Maintaining trust and credibility from customers through the security of sensitive data on the server is a must so that the business can continue to run well.*
- *All processes that require the server cannot be executed if the server is disabled, and all the data in the database cannot be accessed, increasing the vulnerability of sensitive data.*

## Risk Assessment

| Threat source        | Threat event                                           | Likelihood | Severity | Risk |
|----------------------|--------------------------------------------------------|------------|----------|------|
| Hacker               | Conduct DoS (Denial of Service) Attacks on the server. | 3          | 2        | 6    |
| System administrator | Alter/Delete critical information                      | 2          | 3        | 6    |
| Operating            | Misconfigured configurations and                       | 1          | 2        | 3    |

|           |                                                             |  |  |  |
|-----------|-------------------------------------------------------------|--|--|--|
| system(s) | <i>untested upgrades that cause problems in the server.</i> |  |  |  |
|-----------|-------------------------------------------------------------|--|--|--|

## Approach

Risks considered the data storage and management methods of the business. The likelihood of a threat occurrence and the impact of these potential events were weighed against the risks to day-to-day operational needs.

These threats that were chosen are significant business risks , because these threats are related to the database server, in the event of a Denial of Service (DoS) attack, the server could be flooded with too many requests making it inaccessible. The threat of a system administrator misusing the privileges to delete critical information in the database server can be very dangerous as private information could be leaked. And misconfigured operating systems may cause problems such as operational downtime and security vulnerability.

## Remediation Strategy

Implementation of authentication, authorization, and auditing mechanisms to ensure that only authorized users access the database server. This includes using strong passwords, role-based access controls, and multi-factor authentication to limit user privileges. Encryption of data in motion using TLS instead of SSL. IP allow-listing to corporate offices to prevent random users from the internet from connecting to the database. Incorporating the concept of principle of least privilege along with separation of duties to make sure users are assigned with the proper level of access and authorization based on their role. Building a defense in depth for the security in the system can also help prevent future attacks from malicious actors like a DoS attack. Lastly, monitoring OS updates regularly and informing employees about up-to-date technologies and patches will improve the security posture of the organization.